

This competition benefits the consumer through enhanced product offerings at a lower cost. Conversely, competition places additional pressure on financial institutions to protect profitability through the development of new products and services while managing additional marketing, research, and development costs.

Strategic plans that include significant market expansion or the addition of new products and services may expose financial institutions to increased risks. For example, expanding Internet banking services to include electronic bill presentment and payment services, expanding existing bankcard issuing programs, or entering the merchant bankcard processing business significantly increase the potential risk to the financial institution given the inherent risks associated with these services. Business plans for specific products and services should demonstrate that management has assessed the risks and documented the institution's program to mitigate them. Such plans should address the institution's capability to provide the service. Innovative products and services are emerging quickly and early stages of market introduction may expose financial institutions to undefined and unanticipated risks the need for an enterprise wide view of retail payment activities due to cross channel risk including fraud, money laundering, and IT security breaches. Business models for emerging products that are gaining acceptance abroad, particularly in Asia, may not be introduced as easily in the U.S. because of the differences in infrastructure and applications.

To mitigate strategic risk, management should have a strategic planning process ^[41] that addresses its retail payment business goals and objectives, including supporting IT components. Because financial institutions are increasingly reliant upon third-party service providers for retail payment system products and services, the strategic plan should address comprehensive vendor management.

Reputation Risk

Reputation risk occurs when negative publicity regarding an institution's business practices leads to a loss of revenue or litigation. For retail payment-related systems, reputation risk is linked to consumer expectations regarding the delivery of retail payment services, and the institution's ability to meet its regulatory and consumer protection obligations related to those services. An institution's reputation, particularly the trust afforded it by customers and counterparties can be irrevocably tarnished due to perceived or real breaches in its ability to conduct business securely and responsibly.

Financial institutions are responsible for risks associated with the activities of third-party service providers with which they contract. Deficiencies in security and privacy policies that result in the release of customer information by a service provider can damage the reputation of client financial institutions. Operational failures could significantly impact an institution's reputation if systems are disrupted for extended periods. Management oversight of third-party service providers is a critical component of reputation risk management.

Credit Risk

Credit risk arises when a party will not settle an obligation for full value. Each retail payment instrument has a specific settlement process that depends on the entities involved. Multiple financial institutions, third-party entities, as well as the payer and

payee are involved with creating, processing, and settling the transaction. If a financial institution uses a third-party service provider, the institution is responsible for the credit risk exposure for the services performed. Financial institutions should have procedures in place to manage the credit risk of third parties using the institution's accounts to settle transactions.^[42]

Credit risk with retail payment systems is evident in ACH, merchant card, and remote deposit processes where the financial institution supplies funds on behalf of a merchant and provisional settlement does not occur for several days. Returns are another source of credit risk for all forms of retail payment systems. Checks and direct debit transfers can be returned by the payer's institution because of insufficient funds, a closed account, a stop payment order, forgery, fraud, or other payment irregularity. The return timeframes vary for different payment instruments. For an ACH debit, the ODFI grants funds availability to the originator on settlement day. The credit exposure exists until the RDFI can no longer return the ACH debit. If not properly authorized, the return time frame for consumer debits under NACHA rules extends to 60 days from the settlement date.

Financial institutions that accept large volumes of retail payments from merchants should understand the nature and degree of credit risk from those relationships. Financial institutions should manage those relationships in the same manner as any credit, subjecting the customers to credit administration processes for due diligence and ongoing monitoring. The risk in large volume relationships, and the institution's legal lending limit and capital position should be recognized in establishing exposure limits for each customer. Financial institutions may mitigate credit risk by requiring pre-funding for credit originators and adequate risk-based reserves for debit originators.

For the ACH system, NACHA rules require each ODFI to conduct appropriate creditworthiness monitoring, establish exposure limits, and periodically review the limits applicable to specific originating customers. Both ODFIs and RDFIs are exposed to credit risk. However, an RDFI's credit risk is minimal because it has the right to return items it is unable to post to customers' transaction accounts within NACHA guidelines and timeframes. ODFIs are ultimately responsible for all transactions entering the payment system regardless if the transaction is a credit or a debit. ODFIs that generate credits have a typical credit exposure of three days, which represents the gap between the submission of the ACH credit file and the funding of the file by the file originator. Such credit risk may be mitigated by requiring pre-funding of the credit file. ODFIs that generate debits have a credit exposure of 60 days due to the potential for returns.

Bankcards have specific procedures for chargebacks, which are amounts disputed by the cardholder and "charged back" or reversed out of the merchant's account. The acquiring financial institution relies on the creditworthiness of the merchant, but if the merchant declares bankruptcy, commits fraud, or is otherwise unable to pay its chargebacks, the acquiring financial institution must pay the issuing financial institution.

The settlement of retail payment transactions (i.e., the transfer of funds between the parties) discharges the payment obligation. The risk that settlement of retail payment transactions will not take place as expected can result in both credit and liquidity risks. Financial institutions should understand and manage credit and liquidity risks related to the settlement of retail payments. This should include preparing for potential credit and liquidity issues resulting from incomplete settlement or operational problems.

Settlement lags occur when financial institutions, due to failure or the inability to fund their obligations, do not settle their obligations when due. Settlement lags result in credit risk until final settlement occurs. Any payment activity undertaken on the basis of

"unsettled" payment messages remains conditional, resulting in risk. Settlement lags may also result in liquidity risk. Until settlement is completed, a financial institution is not certain what funds it will receive through the payment system. As a result, it may not be sure whether its liquidity is adequate. If an institution overestimates the funds it will receive when settlement takes place, it may face a shortfall. If the shortfall occurs close to the end of the day, an institution could have significant difficulty finding an alternate liquidity source.

Financial institutions often allow their corporate customers to incur intraday or "daylight" overdrafts. An institution engaging in this practice is extending credit to its customer. In most cases, the overdraft is eliminated with incoming funds transfers from other institutions (or outgoing securities transfers against payment) by the end of the business day. Daylight overdrafts constitute an extension of credit, no matter how long they remain unpaid. An institution's credit policies should include provisions for approving and monitoring daylight overdraft lines to customers.

Liquidity Risk

Liquidity risk is the current and potential risk to earnings or capital arising from a financial institution's inability to meet its obligations when they come due without incurring unacceptable losses. Liquidity risk related to payment systems is the risk that the financial institution cannot settle an obligation for full value when it is due but rather at some unspecified time in the future. Liquidity problems can result in opportunity costs, defaults on other obligations, and costs associated with obtaining the funds from an alternative source for possibly extended periods of time. In addition, operational failures may also negatively affect liquidity if payments do not settle within an expected time period.

Legal (Compliance) Risk

Legal risk arises from failure to comply with statutory or regulatory obligations. It can result from a financial institution's failure to comply with the bylaws and contractual agreements established with the bankcard networks, clearing houses, and other counterparties with which it participates in processing, clearing, and settling retail payment transactions. Legal risk also arises if the rights and obligations of parties involved in a payment are subject to considerable uncertainty; for example, if the rights of the parties are not clear when a payment participant declares bankruptcy or if a court interprets an applicable law in an unexpected way. In addition, legal risk can occur when customer agreements or contracts do not clearly establish the roles, responsibilities, governing regulations or guidelines, and dispute resolution processes, particularly with regard to RDC. Legal disputes that delay or prevent the resolution of payment settlement can cause credit, liquidity, or reputation risks at individual institutions. Though unlikely, these disputes also can cause potential systemic risk to the payments system. Legal risk also arises from noncompliance with existing consumer protection statutes, regulations, and case law governing retail payment transactions (e.g., Gramm-Leach-Bliley Act or GLBA, Truth in Lending Act, Regulation CC, and Regulation E). Customer retail payment transaction records and corresponding account information are subject to the GLBA 501 (b) provisions, and financial institutions must establish effective safeguards for protecting their customer information. The bylaws and agreements between clearing house participants and bankcard companies also include specific responsibilities and liabilities.

Financial institutions and third-party service providers that do not comply with the appropriate bylaws and agreements of bankcard companies and clearing houses can be fined or lose their memberships. Thus, financial institutions should assess the risks of accepting such bylaws and agreements in their strategic planning process for new payment offerings. Given the rapidly changing landscape for electronic funds processing, it is paramount for a financial institution to pay close attention to changing legal and regulatory requirements, as well as new network rules that might create unexpected liability for the institution. As financial institutions enter into merchant card, ACH, and remote check processing arrangements with third-party service providers and originators, the institution should ensure that all such arrangements are governed by clearly written contracts which define outsourced responsibilities and liabilities. Financial institutions should carefully review contracts with third parties for outsourced services to ensure that they are not assuming the full risk of loss from failure of third parties to fulfill their contractual responsibilities. Contractual terms may further define responsibilities within the legal framework; and contracts between financial institutions, customers, and third-party service providers may further integrate risk-sharing responsibilities applicable to payments made through a specific clearing or settlement arrangement. In some cases, emerging product development may have insufficient case law to support a completely accurate analysis of the potential risk horizon. The convergence and interoperability of older, more traditional payment methods with newer technologically supported payments may create questions regarding the applicability of law and regulations governing both consumer protection and retail payment transactions. In most cases, older payment technologies for more mature retail payments (checks and credit cards) may co-exist with newer payments technologies requiring financial institutions to maintain several systems. The emergence of hybrid systems that incorporate older technologies with newer payments will require heightened review to mitigate and control legal risks. Hybrid systems and new payment technologies also increase the risk of money laundering as a result of increased volumes, transaction speed, and anonymity. Financial institutions should ensure that due diligence for new payment products or services fully evaluates the applicability of laws and regulations, regulatory guidance, and payment association rules from organizations such as NACHA, Visa, and MasterCard. Recent developments in payments over the ACH system raise legal questions regarding whether payments should be characterized as checks or electronic fund transfers. The same questions arise with respect to RDC and electronically created payment orders. As stated previously, in 2006 the Federal Reserve amended Regulation CC, shifting the liability for losses attributable to unauthorized RCCs to the depository financial institution where the check is first cashed or deposited. The liability creates an economic incentive for depository institutions to perform due diligence on the customers and RCCs. These amendments do not affect the rights of checking account customers, as they are not liable for unauthorized checks drawn on their accounts. The fact that a payment may take several different forms, both paper and electronic, during the course of processing and settlement, creates additional complexity. A payment transaction may be covered by check law, Regulation E, association or clearing house rules, or private agreement, depending on what form the payment takes. Financial institutions should understand the laws and rules that apply to payments they handle and understand the associated legal risks and liabilities they take on with respect to those payments. Bank Secrecy Act (BSA) The BSA requires financial institutions to have BSA/Anti-money laundering (AML) compliance programs and appropriate policies, procedures, and processes in place to monitor, identify unusual activity, and report suspicious activity. As such, all retail payment systems should be reviewed in terms of BSA/AML compliance requirements. The FFIEC BSA/AML Examination Manual includes examiner guidance and expectations for ACH and other payment systems that may require the collaboration of Operational, IT, and BSA examiners. This Booklet does not seek to replicate the guidance and expectations, however, and only a brief summary of this compliance risk is

offered.⁴⁴ Office of Foreign Assets Control (OFAC) OFAC administers and enforces economic sanction programs directed against countries and groups of individuals such as terrorists and narcotics traffickers. All U.S. persons and incorporated entities involved in a payment transaction (i.e., all U.S. citizens and permanent resident aliens, wherever located; all persons and entities within the U.S.; and all U.S. incorporated entities and their foreign branches) are subject to OFAC regulations.⁴⁵ For domestic ACH transactions, the ODFI is responsible for verifying that the originator of the ACH instruction is not a blocked party and for making a good faith effort to determine that the originator is not transmitting blocked funds. The contract between the ODFI and its customer should clearly define the customers' responsibilities to verify that the originator is not a blocked party and to make a good faith effort to determine the originator is not transmitting blocked funds. For high risk originating customers, the ODFI may wish to request that originating customers provide an independent validation of its controls for preventing transmission of funds to blocked parties. The RDFI is responsible for verifying that the receiver of the ACH funds is not a blocked party. For domestic ACH transactions, if ODFIs receive batched transactions from their customers that do not include international ACH transactions, they are not responsible for un-batching transactions and ensuring that they do not process transactions in violation of OFAC's regulations. If the ODFI un-batches the transactions received from its customers, or receives batched international ACH transactions, it is responsible for screening as though it had made the initial batching. For outbound international ACH transactions, on the other hand, the ODFI cannot rely upon the RDFI for OFAC screening. For inbound international ACH transactions, the RDFI is responsible for compliance with OFAC regulations.

Operational Risk

Operational risk is the risk of loss resulting from inadequate or failed internal processes, people and systems, or external events. Operational risk can arise from a technology failure, human or technical errors in financial models and reporting, or other internal control system deficiencies. In the case of RDC, operational risk (i.e., image/data quality, business continuity, information security, etc.) increases when deposit processing occurs at the customer location which is outside of the financial institution's direct control. As a result, the financial institution could experience delays or disruptions in processing, clearing, and settling retail payment transactions that could lead to credit and liquidity problems at other financial institutions.

Operational risk can also arise from fraud perpetrated by employees or by external sources. A financial institution is exposed to operational risk from fraud when a wrongful or criminal deception can lead to a financial loss for one of the parties involved. While fraud risk in traditional ACH activity is low, new ACH products and services, such as one-time ACH debits from Internet-based and telemarketing merchants (WEB and TEL) pose considerable fraud potential. With traditional ACH activity, financial institutions have employed strong front-end fraud controls for recurring debits they originate. These controls are typically not present with WEB and TEL transactions. The continuing growth of check-to-ACH conversion, check truncation, and the growing use of RCCs, RDC, and electronically created payment orders present new forms of fraud risks. In these situations, liability typically rests with the financial institution where the check is first deposited or the ACH item is originated. In the case of electronically created payment orders, liability rests with the financial institution that sends the file to the Reserve Bank or other correspondent. As operational processes continue to change, financial institutions will need to enhance their internal controls, as described below, to mitigate

operational risk. Existing control mechanisms may not be as effective as necessary.

Newer retail payment mechanisms, particularly using the Internet, also subject customers and financial institutions to fraud risk exposure. All of these highly automated processes typically reflect a reengineering of the existing check processes, and the existing fraud controls may not be adequate. The creation of fraudulent electronic transactions could lead to financial losses if fraudulent balances are successfully exchanged for a readily transferable form of funds, such as currency.

Operational risk controls should include sound information systems, and procedural, administrative and legal measures to prevent or limit financial loss. System measures include monetary and time limits (per transaction, per payment instrument, per client), personal authentication, and encryption techniques to ensure the authenticity and integrity of the payer and transaction information. Additional controls include the use of certified, tamper-resistant equipment (e.g., EFT/POS terminals), logical access controls to verify transactions, online verification of account balances, logging of all transactions and attempts to make a transaction, and the use of serial numbers and check digits.

Financial institutions can create a fraud detection control through a due diligence program for new account acceptance coupled with ongoing, automated monitoring of deposit account transactions. Account monitoring should be facilitated through the use of caps, limits, and triggers to measure activity on an intraday basis. Financial institutions use a variety of automated databases, such as credit bureaus, to review new accounts prior to or soon after opening the accounts. Institutions also use a number of vendor-supported automated algorithms to review deposit account transactions for unusual activity related to kiting or other fraud.

Other procedural measures for reducing fraud include: closely monitoring return rates for all customers, appropriate dual custody and separation of duties for critical payment transaction processing and accounting tasks, payment data verification, clear error processing and escalation procedures, and confidential and tamper-resistant mailing procedures for bankcards and other sensitive material. Account reconciliation processes are vital to early detection of errors and fraud. Administrative measures should include IT audit coverage of operational controls, legal controls (including regulatory compliance and agreements), and personnel issues associated with staffing and training.

In the event of an unauthorized use of a payment card, the cardholder's liability is limited to a specified amount if he or she notifies the card issuer of the theft or loss within a set time limit. To limit their own losses from POS card fraud, the bankcard companies require vendors to match the cardholder's signature on the card with the signature on the payment voucher at the POS. The bankcard companies have also introduced extensive monitoring and reporting controls to limit fraudulent activity.

In a broader view of operational risk management, financial institutions should employ vendor management programs that provide for due diligence of new service providers as well as ongoing monitoring of existing vendors. An effective vendor management program will focus on data security and business continuity.

In addition, a more effective approach to mitigate fraud risk may be to view this risk potential across channels. This requires an enterprise view of the range of retail payments activities. Those payments that use multiple payment channels for processing and clearing are subject to an increased level of fraud risk because traditional fraud detection and prevention measures are designed for single channels. Fraud is more likely to migrate to those channels where fraud detection and prevention measures are

less developed.

Mitigation of Operational Risk

Financial institutions should adopt measures that limit operational risks arising from the processing, clearing, and settlement of retail payments. Financial institutions and technology service providers participating in clearing and settlement arrangements for retail payments should ensure operational reliability for timely completion of daily processing through adequate information systems, internal controls, backup facilities, reliable technology, and adequate staff training and support. Furthermore, these organizations should adopt business continuity plans to minimize and manage the effects of interruptions. Risk analysis should identify confidential assets, critical operations, and potential threats. It should also define safeguards and countermeasures to provide appropriate protection.

Risk from fraud or error from customers that generate high volumes of RDCs, electronically created payment orders, or RCCs can be managed more effectively with the use of activity and fraud monitoring tools for those customers. Financial institutions that originate large volumes of ACH transactions directly or through third-party service providers should also consider these tools as part of their due diligence. Fraud databases and fraud analysis tools can assist financial institutions in detecting and controlling potential fraud risk. Some bankcard associations and Internet banking applications use neural network technologies or behavioral fraud analysis. These technologies utilize specialized software and hardware designed to identify patterns of behavior that enable financial institutions to identify suspicious transactions or spending. The bankcard companies have also developed numerous fraud detection and avoidance systems that member financial institutions can use to reduce losses as a result of fraudulent bankcard use. The growth of e-commerce has led many financial institutions and service providers to develop additional databases that provide early identification of potential fraud.

Identifying, evaluating, and addressing potential legal and compliance risks associated with new payment systems providers can also help mitigate operational risk. For example, a thorough legal review process can ensure that there are clearly defined roles and responsibilities for the financial institution, its service providers, and its customers. Financial institutions should also comply with the regulations and consumer compliance mandates that apply to retail payment services (e.g., Regulation E).

Financial institutions also should have appropriate risk control functions such as audit, information security, vendor management, and business continuity, as discussed in the following sections.

Audit

Action Summary

The board of directors should ensure that an effective internal audit function for the financial institution's payment systems is in place. The audit program should test the quality of retail payment systems internal controls and compliance with laws, regulations, management policies, procedures, and limits. Audit coverage should be

risk-focused and should cover all retail payment systems including third party relationships. Special attention should be given to new retail payment technologies and products.

An effective audit function should include internal and external audit coverage, tailored to the complexity of the financial institution, and based upon an accurate, enterprise-wide assessment of the institution's risk profile. Due to the potentially large transaction volumes and associated dollar value when initiating payments, internal audit coverage is critical for an effective oversight of the financial institution's retail payment systems. Auditors should perform an evaluation of the financial institution's retail payment system business lines on the basis of overall risk to the financial institution. Based on this evaluation, they should develop an appropriate schedule of audits. The audit coverage should be sufficient to validate the internal control environment surrounding the processing, clearance, and settlement of retail payment transactions. Auditors should review accounting controls and assess the effectiveness of transaction processing, clearance, and settlement processing procedures.

The board of directors should ensure the operational and IT audit program tests retail payment system internal controls, management policies, and procedures. IT audit coverage should include the design and implementation of retail payment products, and the supporting IT environment encompassing internal data centers, contingency sites, and network infrastructure. IT audit coverage should verify the adequacy of internal controls in applicable business lines responsible for managing day-to-day retail payment system services. Internal audit should assess the comprehensiveness of the institution's vendor management program to ensure the institution is appropriately managing vendor risk. ^[43] Internal audit should also evaluate payment systems when conducting BSA audits.

Information Security

Action Summary

Financial institutions should implement the appropriate physical and logical security controls to ensure retail payment system transactions are processed, cleared, and settled in an accurate, timely, and reliable manner. Security risk assessments should consider physical and logical security controls for the origination, approval, transmission, and storage of retail payment system transactions. Risk assessments should include service providers, third-party originators, and external networks that process, store, or transport customer data. Physical controls should limit access to only those staff assigned responsibility for supporting the operations and business line centers that process retail payment and accounting transactions. Physical controls should also provide for the ability to monitor and document access to these facilities. Logical controls should include identifying and authenticating retail payment system customers to help ensure the integrity of the payments. Particular attention to data security is required for emerging technologies.

Financial institutions should implement the appropriate physical and logical security controls to ensure retail payment system transactions are processed, cleared, and settled in an accurate, timely, and reliable manner. Retail payment systems contain confidential customer information subject to GLBA section 501(b) security guidelines. Payments data may also be subject to the requirements of the Payment Card Industry Data Security Standard (PCI DSS). ^[44] The board and management are responsible for protecting the confidentiality, integrity, and availability of these systems and data. The privacy risk combined with the funds transfer capability should cause these systems to rank high in all institutions' information security risk assessments. The risk assessments should consider physical and logical security controls for the origination, approval, transmission, and storage of retail payment system transactions.

Physical controls should limit access to sensitive areas to staff assigned responsibility for supporting the operations and business line centers that process retail payment and accounting transactions. Physical controls should also provide for monitoring and documenting access to these facilities.

Management should assign appropriate logical access to staff responsible for retail payment-related services and should base access rights on the need to separate the duties of personnel responsible for originating, approving, and processing the transactions. Appropriate identification and authentication techniques include requiring unique authenticators for each staff member with strong password requirements.

Logical access controls should permit access on a need-to-know basis and should assign access to retail payment applications and data based on functional job duties and requirements. Logical access controls should also protect network access. An institution's risk assessment should require protection of retail payment systems from unauthorized access through appropriate access controls, network and host configuration, operation, firewalls, and intrusion detection and monitoring. The risk assessment should also review the security of all third-party service providers. Some institutions accomplish this by isolating all payment-related applications and systems from other production applications.

A critical element in ensuring retail payment systems integrity is the appropriate identification and authentication of retail payment system customers. Transaction authorization (e.g., the approval of a funds transfer or guarantee of funds) is an essential precondition leading to the interbank transfer of funds. Financial institutions should establish an adequate internal control environment for the issuance of bankcards and related PIN. These controls can minimize processing errors and fraud and protect the confidentiality of customer and institution information.

The use of newer and emerging technologies presents new security challenges. As new retail payment products and services are developed, it may become necessary to modify methods for customer identification and authentication to ensure their effectiveness.

Many electronic banking applications use Internet-based, open network standards and rely on commonly accepted technologies to secure transmissions (e.g., secure socket layer [SSL] or other virtual private network [VPN]). The institution should establish a secure session before consumers can submit their personal banking information, and

should maintain the secure session until the time of final data transmission.

Retail payment systems should incorporate sufficient security procedures and controls to verify the integrity of the data, the confidentiality of the transmission, and the authenticity of the communication partners and data sources. The selection and use of authentication technologies and methods should depend upon the results of a financial institution's risk assessment process. Where risk assessments indicate that the use of single-factor authentication is inadequate, financial institutions should implement multifactor authentication, layered security, or other controls reasonably calculated to mitigate those risks. Single factor authentication alone is inadequate for high-risk transactions involving access to customer information or the movement of funds to other parties. Using digital certificates, leveraging the public key infrastructure (PKI), employing biometrics and card or token-based techniques can provide cost-effective solutions for augmenting traditional technical controls. ^[45]

Institutions that participate in payment card systems should develop processes to ensure compliance with the PCI DSS. This standard is discussed further in the "Merchant Acquiring" section.

Institutions should have a response program in place that addresses security breaches, including incidents with their third-party servicers. The program should include the investigation, customer notification, if applicable, and reporting processes for regulatory and law enforcement agencies.

Business Continuity Planning

Action Summary

Financial institutions and their TSPs should develop, implement, and test appropriate disaster recovery and business continuity plans capable of maintaining acceptable retail payment-related customer service levels. For financial institutions and service providers with complex retail payment operations, business continuity plans should enable restoration of service within timeframes that are reasonable for internal business units as well as other dependent financial institutions and counterparties.

Effective business continuity planning is an important component in managing operational risk. Financial institutions and their TSPs should develop, implement, and test appropriate disaster recovery and business continuity plans capable of maintaining acceptable retail payment-related customer service levels. Business continuity plans should be based on business impact analyses and the relative importance of retail payment system products and services to the financial institution. ^[46]

For financial institutions offering basic retail payment products and services (e.g., bankcard issuance, check item processing, branch ATM access, Internet banking services), business continuity plans should include appropriate recovery targets for each retail product. The recovery targets should consider the reliance on any third-party servicer in meeting their objectives. Vendor management programs should include provisions for the disruption and restoration of service at service providers, including the consideration of service provider test plans.